

Manual 37 — Implementação Controlada de Proteção de Dados / Habeas Data da Colômbia

****Idioma:**** Português do Brasil (pt-BR)

****Linha de base controlada:**** Ley Estatutaria 1581 de 2012, disposições aplicáveis consolidadas no Decreto 1074 de 2015 e instruções vinculantes vigentes da SIC verificadas em 31-08-2026.

****Limite:**** Direitos constitucionais, lei, decreto, instruções SIC vinculantes, orientação/enforcement SIC, regimes especiais, contratos e prática organizacional permanecem separados. Esta é tradução de projeto não oficial, não aconselhamento jurídico nem aprovação da SIC.

Chapter 01 — Objetivo, escopo e hierarquia controlada de fontes

Use princípios constitucionais de privacidade/habeas data, Ley 1581, decretos aplicáveis e instruções SIC vinculantes conforme seu status real. Mantenha separadas orientações, enforcement, regimes especiais, contratos e procedimentos internos.

Preserve registro datado de fontes, owner de aplicabilidade, change watch e reverificação de release.

Chapter 02 — Contexto constitucional de habeas data e privacidade

Mapeie direitos constitucionais de acesso, atualização, retificação, circulação, privacidade e autodeterminação informacional, distinguindo-os das obrigações operacionais da Ley 1581 e regimes setoriais.

Preserve source mapping, policy traceability, procedimentos de direitos e critérios de escalonamento.

Chapter 03 — Aplicabilidade, exclusões e análise jurisdicional

Documente se cada tratamento está no regime geral, em uma exclusão ou em regime especial. Não presuma que todas as bases ou entidades são reguladas da mesma forma.

Preserve applicability assessments, fatos, exclusões, overlays especiais, reviewers e gatilhos de reavaliação.

Chapter 04 — Categorias de dados e conceitos de tratamento

Mantenha definições controladas de dados pessoais, sensíveis, públicos, privados e semiprivados; tratamento; banco de dados; titular; responsável; encarregado e conceitos relacionados.

Preserve glossário, classificação, exemplos, decisões e histórico de mudanças.

Chapter 05 — Responsável, encarregado e accountability

Identifique papéis reais segundo decisões, instruções e fatos, não apenas labels contratuais. Defina accountability, escalonamento, rights support, segurança, incidentes e evidência.

Preserve matrizes, instruções, contratos, owners e revisões.

Chapter 06 — Governança, políticas e supervisão

Estabeleça governança aprovada com ownership, funções responsáveis, oversight executivo, issue escalation, assurance e management review periódico. Integre privacy com security, legal, procurement, RH, produto, data, operações e risk.

Preserve policies, RACI, comitês, training, dashboards, issues e corrective actions.

Chapter 07 — Inventário, registro de tratamento e fluxos

Mantenha inventário de databases, systems, finalidades, categorias, sensíveis, titulares, fontes, recipients, encarregados, localizações, transfers/transmissions, retention, security e owners.

Atualize por mudanças de negócio, tecnologia, finalidade, vendor, fluxo ou lei.

Chapter 08 — Autorização/consentimento e exceções

Quando autorização for exigida, colete evidência informada para finalidades definidas. Quando houver exceção, documento fundamento e fatos em vez de fabricar consent evidence.

Preserve texto/versão, timestamp, método, finalidade, revogação e exception rationale.

Chapter 09 — Avisos de privacidade e deveres de informação

Mantenha avisos/policies coerentes com tratamento real, autorização, finalidades, direitos, identidade do responsável, contatos, dados sensíveis, transferências/transmissões e condições relevantes.

Preserve versões, approvals, publicação, readability e reconciliação com sistemas.

Chapter 10 — Finalidade, necessidade, proporcionalidade, qualidade e circulação restrita

Limite tratamento e circulação a finalidades legítimas, informadas e autorizadas ou legalmente permitidas. Mantenha qualidade razoável, proporcionalidade, necessidade, confidencialidade e access restriction.

Preserve purpose registers, minimization reviews, quality controls, access reviews e remediation.

Chapter 11 — Controles de dados sensíveis

Trate dados sensíveis como risco elevado. Documente finalidade, base/autorização, necessidade, transparência, access restriction, security, sharing, retention e exceções aplicáveis.

Preserve inventories, assessments, authorization/exception evidence, access e tests.

Chapter 12 — Dados de crianças e adolescentes

Aplique governança reforçada incluindo melhor interesse, direitos fundamentais, purpose limitation, transparência, minimização, security e autorização/exceção legal adequada.

Preserve context assessment, notices, authorization analysis, safeguards e remediation.

Chapter 13 — Consultas, reclamações, correção, atualização, supressão e revogação

Opere procedimentos documentados para consultas/reclamações e correção, atualização, supressão e revogação quando cabíveis. Encaminhe conforme processo vigente e papel da organização.

Preserve logs, scope, buscas, decisões, respostas e closure evidence.

Chapter 14 — Validação de identidade, representação, prazos e evidência

Verifique identidade/representação proporcionalmente, proteja contra disclosure não autorizado e acompanhe prazos legais e extensões. Diferencie deadlines legais de service targets voluntários.

Preserve identity evidence, timestamps, correspondence, extensions e metrics.

Chapter 15 — Salvaguardas de segurança

Implemente controles administrativos, técnicos e físicos proporcionais. Integre IAM, secure configuration, encryption quando apropriado, logging, vulnerability management, secure development, physical security, monitoring, resilience e incident response.

Preserve mappings, tests, vulnerabilities, exceptions e corrective actions.

Chapter 16 — Incidentes, escalonamento e reporte

Use processo documentado para determinar afetação de dados, preservar evidência, avaliar alcance/dano, escalar e cumprir obrigações SIC/RNBD onde aplicáveis. Não trate reportes RNBD como universais sem applicability analysis.

Preserve facts, detection time, assessment, decision authority, reporting evidence e remediation.

Chapter 17 — Risco de privacidade e tratamento de alto risco

Avalie risco para dados sensíveis, grupos vulneráveis, monitoring, profiling, grande escala, novas tecnologias ou secondary use inesperado. Aplique controles adicionais e management escalation quando necessário.

Preserve methodology, assessments, residual risk, safeguards e approvals.

Chapter 18 — Aplicabilidade e operação do RNBD

Documente se a entidade/bases atendem aos critérios vigentes de registro e mantenha registros/updates apenas quando exigidos. Preserve thresholds, categories, update duties, incident relationships e mudanças da Circular Única.

Preserve applicability analysis, RNBD records, update logs e incident evidence.

Chapter 19 — Transferências internacionais e exceções

Para transferências em que o receptor atua como responsável, avalie destino, condições, exceções, mecanismos de conformidade, autorização ou outros requisitos vigentes. Não trate declaração de conformidade como permissão geral.

Preserve transfer inventory, recipient role, mechanism/exception, SIC evidence, contracts e reassessment.

Chapter 20 — Transmissões nacionais/internacionais e contratos de encarregado

Para transmissions sob instruções, mantenha acordos que definam scope, purpose, security, confidentiality, rights support, incidents, subcontracting, deletion/return e transfer conditions.

Preserve transmission register, agreements, instructions, due diligence e monitoring.

Chapter 21 — Lifecycle de vendors, encarregados e terceiros

Avalie terceiros antes e durante a relação. Alinhe role classification, instructions, purposes, security, rights support, incident cooperation, location, international flows, retention, audit e exit.

Preserve due diligence, contracts, registers, monitoring, findings e termination evidence.

Chapter 22 — Cloud, SaaS, serviços gerenciados e responsabilidade compartilhada

Mapeie locations, support access, admins, subprocessors, telemetry, backups, encryption, retention, deletion, controls e flows internacionais. Resolva papéis e cross-border conditions antes de produção.

Preserve architecture/data-flow maps, configurations, shared responsibility, contracts e exit plans.

Chapter 23 — Marketing, analytics, profiling, monitoring e canais digitais

Governe marketing, cookies/trackers, analytics, profiling, personalization e monitoring conforme authorization, notice, purpose, necessity, security e rights. Mapeie overlays consumer/e-commerce separadamente.

Preserve use-case assessments, basis, notices, configuration evidence e complaints.

Chapter 24 — Dados laborais

Aplique deveres gerais a empregados, candidatos e contractors separando normas trabalhistas e outras especiais. Limite access/monitoring a finalidades documentadas e controles proporcionais.

Preserve workforce notices, authorization/exceptions, access reviews, retention e training.

Chapter 25 — Retenção, arquivo, supressão e descarte

Defina retention conforme finalidade, lei, claims, records, contracts e necessidade. Implemente deletion, suppression/blocking, archive, backup e secure disposal conforme fundamento aplicável.

Preserve schedules, deletion/suppression evidence, legal holds e disposal records.

Chapter 26 — Circulares SIC, investigações, sanções e readiness

Mantenha obligation register que diferencie instruções/circulares vinculantes de guidance, concepts, FAQs, enforcement facts e propostas. Prepare resposta controlada a investigações e requerimentos.

Preserve SIC register, investigation protocol, legal holds, response packages, findings e corrective actions.

Chapter 27 — Regimes setoriais e especiais

Identifique habeas data financeiro/credício, health, telecom, employment, children, public-sector, consumer, electoral e outros regimes separados do marco geral.

Preserve overlay matrices, applicability decisions, citations, owners e change watch.

Chapter 28 — Arquitetura de evidência e audit trail

Crie rastreabilidade de requirement/source até owner, procedure, system/control, test, exception, remediation e decision. Proteja integrity, access, confidentiality, retention e version history.

Preserve evidence indexes, control maps, workpapers, logs, approvals e provenance.

Chapter 29 — Exceções, remediação e risk acceptance

Exija exceções com scope, rationale, compensating controls, owner, approval, residual risk, duration e expiration. Escala issues vencidos/materiais a management e liderança legal/privacy.

Preserve exception registers, corrective actions, risk acceptances, dashboards e closure evidence.

Chapter 30 — Reformas e change watch SIC

Monitore mudanças promulgadas à Ley 1581/Decreto 1074, Circular Única Título V, RNBD, incidentes, transfer/transmission procedures, regras corporativas vinculantes, sanções e overlays. Trate propostas apenas como change-watch até vigência.

Preserve source snapshots, change assessments, implementation plans e effective dates.

Chapter 31 — Exact-hash, localização, provenance e release evidence

Congele controlled source antes do candidate build. Vincule EN/es-419/pt-BR DOCX/PDF a SHA-256 exatos e preserve accessibility, render, localization, source, workflow-security e release-QA.

Toda mudança material pós-freeze exige supersession, regeneration, re-hashing e re-review.

Chapter 32 — Roadmap, maturidade e reverificação de release

Implemente em fases: applicability/inventory, authorizations/notices, rights, RNBD, security/incidents, transfers/transmissions/vendors, high-risk uses e assurance/evidence. Meça maturidade com outcomes respaldados por evidência.

Antes de publicar, reverifique Ley 1581/2012, Decreto 1074/2015, Circular Única Título V, RNBD/incidents, transfer/transmission procedures, processos de conformidade 2026, binding corporate rules, sanctions/enforcement e reformas promulgadas. Publicação permanece após o Manual 36 com todos os gates em verde.